

Assignment 1

Course: Network Security

Name: Asim Shakeel

Registration No: 22P-9229

1. Protocol Purpose and Real-World Scenario:

Purpose:

The objective of this protocol is to establish mutually authenticated secure communication and perform session key exchange between a client A and a server B. The protocol also protects a secret Payload that is shared between the two communicating entities.

To achieve this, the protocol relies on a Trusted Third Party (s) that verifies the identity of the client and confirms its authenticity to the server.

Real-World Scenario:

This protocol represents a Single Sign-On (SSO) or federated identity system.

In this scenario:

- 1) A represents a user's client device.
- 2) B represents a service provider or application server.
- 3) s represents a central Identity Provider (IdP) that performs authentication.

The client A already shares a secret key $sk(A,s)$ with the identity provider s. When the client attempts to access a service hosted by B, the identity provider verifies the client's identity and confirms it to B, allowing secure communication between them.

2. OFMC Attack and Broken Goal:

The Attack:

Using the OFMC (On-the-Fly Model Checker) tool, a Man-in-the-Middle / Impersonation attack is detected.

The attack occurs in the following way:

1. Client A sends an encrypted message intended for B, but the attacker I intercepts it.

$A \rightarrow I : \{A, I, NA, KAB\}_{pk(I)}$

2. Since the message is encrypted with the attacker's public key, the attacker decrypts it and learns the nonce NA.

3. The attacker then starts a new session with B, pretending to be A:

$I(A) \rightarrow B : \{A, B, NA, KABI\}_{pk(B)}$

4. Later, when A legitimately authenticates with the trusted server s, the server sends a signed confirmation to B:

$s \rightarrow B : \{A, NA, s\}_{inv(pk(s))}$

5. The attacker allows this message to reach B.

Since the nonce NA matches the one received earlier, B believes it is communicating securely with A, even though the attacker is controlling the session.

Broken Goal:

The attack breaks the security goal:

“B authenticates A on NA.”

Although the protocol appears to complete successfully from B's perspective, the communication is actually controlled by the attacker. Therefore, authentication of A by B fails, making the protocol insecure.

3. Fixing the First Attack

The Fix:

The vulnerability occurs because the trusted server s issues a signature that does not explicitly specify the intended responder. This allows an attacker to reuse the authentication message in another session.

To prevent this issue, the protocol must bind the identity of the responder (B) to the authentication message. This ensures that the authentication token cannot be reused in a different session or with another server.

Modified Messages:

$A \rightarrow s : \{A, B, NA\}_{sk(A,s)}$

$s \rightarrow B : \{A, B, NA, s\}_{inv(pk(s))}$

In this modification:

The identity of B is included in the message sent by A to s .

The trusted server s includes B in its signed response.

This ensures that the authentication response is only valid for communication between A and B , preventing impersonation attacks.

4. Guessable Secret Attack and Fix

The Problem:

When the goal “ $sk(A,s)$ guessable secret between A,s” is introduced, a new vulnerability appears.

The protocol becomes susceptible to an offline dictionary attack.

During the authentication process, A sends the following message to the trusted server:

$A \rightarrow s : \{A, NA\}_{sk(A,s)}$

An attacker who intercepted this message already knows the plaintext values (A, NA).

Using this information, the attacker can perform the following steps:

1. Capture the encrypted message.
2. Guess possible values for the secret key $sk(A,s)$ from a dictionary of weak passwords.
3. Encrypt the known plaintext using each guessed key.
4. Compare the result with the captured ciphertext.

If the values match, the attacker successfully discovers the secret key.

Result:

This means that if $sk(A,s)$ is weak or guessable, the attacker can recover it without interacting with the server, purely through offline brute-force attempts.

Therefore, the protocol becomes vulnerable to offline password guessing attacks, which compromises the shared secret between A and s.